

設備安全配對 API 與 ESP32 互動規範

基本資訊

項目	內容
對應檔案	api/大概是 API 吧/device_pair/device_pair.py 或 api/cgi-bin/device_pair.py
方法	POST
Endpoint	/cgi-bin/device_pair.py
Content-Type	application/json; charset=utf-8
是否使用 ECDH	是，secp256r1 / P-256
App 互動	Admin App 發起設備註冊與配對。
ESP 互動	ESP32 提供 ECDH public key；API 回傳 Gateway public key 與配對結果。

POST Request Parameters

欄位	型別	Required	說明
owner_user_id	string	true	裝置擁有者或 Admin user_id。
family_id	integer	false	設備所屬家庭 / 場域 ID。
gateway_id	string	false	Gateway ID，預設 GW_001。
device_id	string	true	終端設備 ID。
device_name	string	false	設備顯示名稱。
device_type	string	true	設備類型。
device_public_key_pem	string	false	ESP32 傳來的 ECDH public key PEM；省略時可模擬。

App / ESP32 → API Request Packet

```
{
  "payload": {
    "owner_user_id": "admin_001",
    "family_id": 12,
    "gateway_id": "GW_001",
    "device_id": "ESP32_LOCK_001",
    "device_name": "客廳門鎖",
    "device_type": "smart_lock",
    "device_public_key_pem": "-----BEGIN PUBLIC KEY-----..."
  }
}
```

Processing Rules

編號	規則
1	讀取 POST JSON payload。
2	檢查 owner_user_id、device_id、device_type。
3	Gateway 產生 ECDH private/public key。
4	若未提供 device_public_key_pem，建立模擬 ESP32 key。
5	計算 shared secret，透過 HKDF 派生 session key。
6	只保存 session_key_hash，不保存明文 session key。
7	寫入/更新 devices，設為 Active、paired。
8	寫入 audit_logs，action=DEVICE_REGISTERED。

API 對 SQL 寫入內容

資料表	寫入 / 更新欄位	觸發時機與說明
devices	INSERT / UPDATE device_id, device_name, device_type, family_id, gateway_id, owner_user_id, device_public_key, gateway_public_key, session_key_hash, pairing_status, paired_at, status	設備配對成功時寫入或更新。
audit_logs	INSERT DEVICE_REGISTERED / DEVICE_PAIRED	配對成功後寫入稽核。
users	SELECT users.user_id / id	取得操作者資料；測試版查不到時可不阻擋。

API → App / ESP32 Response Packet

```
{
  "status": "Success",
  "msg": "裝置註冊與安全配對成功",
  "data": {
    "device_id": "ESP32_LOCK_001",
    "pairing_status": "paired",
    "ecdh_curve": "secp256r1",
    "gateway_public_key_hash": "sha256_hex",
    "session_key_hash": "sha256_hex",
    "ledger": {
      "command_id": "tx-uuid",
      "prev_hash": "previous_hash",
      "current_hash": "current_hash"
    }
  }
}
```

Error Responses

HTTP 狀態	錯誤碼	說明
400	INVALID_JSON / MISSING_FIELD	JSON 格式錯誤或缺少必要欄位。
403	ROLE_DENIED / TOKEN_FORMAT_INVALID / TOKEN_EXPIRED / TOKEN_USED_UP	角色不符、訪客令牌格式錯誤、過期或次數耗盡。
404	DEVICE_NOT_FOUND / FAMILY_NOT_FOUND / TOKEN_NOT_FOUND	查無設備、場域或令牌。
409	DEVICE_REVOKED / DUPLICATE_RECORD	設備狀態衝突或不可重複操作。
500	DB_DRIVER_MISSING / INTERNAL_ERROR	資料庫驅動、SQL 或伺服器內部錯誤。

注意事項

- 正式版 ESP32 應提供自己的 device_public_key_pem，不應依賴模擬 key。
- session key 明文不得寫入資料庫或 log。
- 已除役 device_id 不應直接重新配對，需建立重新啟用流程。

App 呼叫範例

App 端以 HTTPS POST 送出 JSON；本機測試可用 curl 或 printf 對應 CGI stdin。

```
POST /cgi-bin/device_pair.py
Content-Type: application/json; charset=utf-8

{
  "payload": {
    "owner_user_id": "admin_001",
    "family_id": 12,
    "gateway_id": "GW_001",
    "device_id": "ESP32_LOCK_001",
    "device_name": "客廳門鎖",
    "device_type": "smart_lock",
    "device_public_key_pem": "-----BEGIN PUBLIC KEY-----..."
  }
}
```

```
curl -X POST "http://localhost:8000/cgi-bin/device_pair.py" \
-H "Content-Type: application/json" \
-d '{"payload": {"owner_user_id": "admin_001", "family_id": 12, "gateway_id": "GW_001", "device_id": "ESP32_LOCK_001",  
"device_name": "客廳門鎖", "device_type": "smart_lock", "device_public_key_pem": "-----BEGIN PUBLIC KEY-----..."}}'
```